Pickle Rick — TryHackMe (Fácil)

Plataforma: TryHackMe **Dificultad:** Fácil **Categorías:** Reconocimiento web, análisis de código fuente, command injection, escalada de privilegios en Linux **Herramientas:** Nmap, Gobuster, curl, CyberChef, navegador web

Índice

1. Resumen
2. Reconocimiento
3. Enumeración web
4. Acceso al panel de comandos
5. Ingrediente 1
6. Ingrediente 2
7. Ingrediente 3
8. Lecciones aprendidas
9. Mitigaciones
10. Referencias

Resumen

Pickle Rick es una máquina Linux temática de Rick and Morty con foco completamente web. Las credenciales de acceso están expuestas en el código fuente de la página principal y en `robots.txt`. Con ellas se accede a un panel de administración con ejecución remota de comandos (RCE), que permite explorar el sistema de archivos y encontrar los tres ingredientes ocultos. El usuario del servidor web tiene permisos de sudo irrestrictos, lo que convierte cualquier exploración en acceso root de facto.

1. Reconocimiento

Escaneo de puertos con detección de versiones:

```
nmap -sC -sV <IP>
```

Puerto	Servicio	Versión
22	SSH	OpenSSH 8.2p1 Ubuntu
80	HTTP	Apache 2.4.41 (Ubuntu)

El servidor SSH solo acepta autenticación por clave pública (`Permission denied (publickey)`), por lo que el vector principal es el servicio web en el puerto 80.

2. Enumeración web

Código fuente de la página principal

La página principal mostraba un mensaje narrativo sin información técnica visible. Sin embargo, el código fuente (`Ctrl+U`) contenía un comentario HTML con una credencial:

```
<!-- Note to self, remember username! Username: R1ckRul3s -->
```

Los comentarios HTML son completamente invisibles en el navegador pero visibles para cualquiera que inspeccione el código fuente. Esta es una práctica de seguridad deficiente muy común en aplicaciones web mal desarrolladas.

robots.txt

```
curl -s http://<IP>/robots.txt
```

El archivo contenía una sola palabra que resultó ser la contraseña del panel de administración.

Gobuster

```
gobuster dir -u http://<IP>/ -w /usr/share/wordlists/dirb/common.txt
gobuster dir -u http://<IP>/ -w /usr/share/wordlists/dirb/big.txt
```

Ninguna de las dos wordlists encontró las páginas PHP relevantes (`login.php`, `portal.php`). Esto confirma que Gobuster depende completamente de la wordlist usada — rutas con nombres específicos del contexto no aparecen en listas genéricas. Fueron descubiertas probando rutas comunes manualmente en el navegador.

3. Acceso al panel de comandos

Con las credenciales obtenidas:

- **Usuario:** `R1ckRul3s` (del comentario HTML)
- **Contraseña:** (de `robots.txt`)

Se accedió a `http://<IP>/login.php`, que redirige a `http://<IP>/portal.php` tras autenticarse correctamente.

El portal expone un **Command Panel**: un campo de texto con un botón "Execute" que envía comandos al servidor vía POST y muestra el resultado en la página. Esto es ejecución remota de comandos (RCE) directa — cualquier comando Linux válido se ejecuta en el servidor con los permisos del proceso web (`www-data`).

Verificación del nivel de acceso

sudo -l

Resultado: (ALL) NOPASSWD: ALL

El usuario `www-data` puede ejecutar **cualquier comando como cualquier usuario**, incluyendo root, sin contraseña. Es la configuración de sudo más permisiva posible.

Nota sobre comandos bloqueados

El panel tiene una lista negra que bloquea ciertos comandos, incluyendo `cat`. Los filtros basados en listas negras son inherentemente eludibles porque es imposible bloquear todos los comandos equivalentes. Alternativas funcionales:

less tac grep .

4. Ingrediente 1

Listado del directorio web actual: ls

Se encontró el archivo `Sup3rS3cretPickl3Ingred.txt` en el directorio raíz del servidor web. Lectura con alternativa a `cat`: less Sup3rS3cretPickl3Ingred.txt

También se encontró `clue.txt`, cuyo contenido indicaba buscar en el sistema de archivos para los ingredientes restantes.

5. Ingrediente 2

Exploración del sistema de archivos: sudo find / -name “ingredient” 2>/dev/null

Se encontró el archivo `/home/rick/second ingredients` (nombre con espacio incluido). Las comillas son necesarias para que la terminal interprete el nombre como un único argumento: sudo less “/home/rick/second ingredients”

Distractor: comentario en el código fuente del portal

El código fuente de `portal.php` contenía un comentario con una cadena codificada en base64. Tras decodificarla **7 veces** consecutivas en CyberChef, el resultado fue `rabbit hole` — una pista intencional del creador de la sala indicando que ese camino era un distractor. Es una técnica común en CTFs para consumir tiempo del atacante.

6. Ingrediente 3

El tercer ingrediente estaba en la carpeta de root, accesible gracias a los permisos de sudo irrestrictos:

sudo ls /root sudo less /root/3rd.txt

Lecciones aprendidas

- Los comentarios HTML son invisibles en el navegador pero completamente legibles en el código fuente. Nunca incluir credenciales, rutas internas ni información sensible en comentarios de páginas web públicas.
- `robots.txt` es un archivo público — cualquier dato incluido ahí es accesible para cualquier visitante, no solo para buscadores.
- Un Command Panel que ejecuta input del usuario directamente en el sistema operativo es una vulnerabilidad de RCE crítica, independientemente de la lista negra de comandos que tenga.
- Los filtros de lista negra son siempre eludibles. La forma correcta de prevenir RCE es no ejecutar input del usuario como comandos del sistema, no intentar filtrar comandos específicos.

- `sudo (ALL) NOPASSWD: ALL` es la configuración de sudo más peligrosa posible — equivale a dar acceso root completo sin autenticación a cualquier proceso que corra con ese usuario.
- Gobuster no es exhaustivo: solo encuentra rutas que están en su wordlist. Rutas con nombres específicos del contexto requieren prueba manual o wordlists especializadas.
- Archivos con espacios en el nombre requieren comillas en la terminal para ser interpretados como un solo argumento.
- Los "rabbit holes" son distractores intencionales en CTFs — reconocerlos a tiempo ahorra mucho esfuerzo.

Mitigaciones (perspectiva defensiva)

- Nunca incluir credenciales ni información sensible en comentarios HTML, `robots.txt` ni ningún archivo público.
- No implementar paneles de ejecución de comandos del sistema en aplicaciones web. Si es absolutamente necesario, usar listas blancas estrictas de comandos permitidos, no listas negras.
- Configurar sudo con el principio de mínimo privilegio: solo los comandos estrictamente necesarios, nunca `ALL`.
- Usar contraseñas robustas para paneles de administración y protegerlos con autenticación multifactor.

Referencias

- TryHackMe — Pickle Rick
- OWASP — Command Injection